

SecureOrg Inc.

PCI DSS Compliance Framework

Password Policy

Document Reference:	PWP-008
Version:	1.5
Effective Date:	April 14, 2026
Document Owner:	Chief Information Security Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Password Policy establishes the requirements for creating, managing, and protecting passwords and authentication credentials for all systems within SecureOrg Inc., with mandatory enhanced requirements for cardholder data environment systems. The Policy implements PCI DSS v4.0 Requirement 8 (Identify Users and Authenticate Access to System Components), which mandates strong authentication to prevent unauthorized access to CHD.

1.2 Scope

This Policy applies to all user accounts, service accounts, system accounts, and administrative accounts on all company systems. Enhanced requirements apply specifically to systems within or connected to the cardholder data environment.

2. Password Requirements

2.1 Standard Account Password Requirements

The following minimum requirements apply to all standard user accounts across company systems:

Minimum Length	8 characters	12 characters	Req 8.3.6
Complexity	3 of 4 character types	All 4 character types required	Req 8.3.6
Maximum Age	180 days	90 days	Req 8.3.9
Minimum Age	1 day	1 day	Req 8.3.9
Password History	Last 8 passwords	Last 12 passwords	Req 8.3.7
Account Lockout Threshold	10 attempts	6 attempts	Req 8.3.4
Lockout Duration	15 minutes	30 minutes or admin unlock	Req 8.3.4
Observation Window	15 minutes	30 minutes	Req 8.3.4

2.2 Password Complexity Requirements

Passwords must contain characters from at minimum three (standard) or all four (CDE) of the following categories:

- Uppercase letters: A–Z
- Lowercase letters: a–z
- Numbers: 0–9
- Special characters: ! @ # \$ % ^ & * () _ + - = [] { } ; ' : " , . < > ? / \ |

Passwords must not contain:

- The user's username, first name, last name, or display name
- Common words, phrases, or keyboard sequences (password123, qwerty, 12345678)
- Sequential numbers or letters (abcdef, 123456)
- The organization name or common derivatives
- Words from a dictionary that are not combined with complexity elements

2.3 Privileged Account Password Requirements

Accounts with administrative, privileged, or service privileges are subject to the following additional requirements:

- Minimum 16 characters for all privileged accounts

- Maximum age of 60 days
- Use of a password manager or privileged access management (PAM) solution is mandatory
- MFA required for all privileged account logins without exception
- Privileged account usage must be reviewed weekly

3. Multi-Factor Authentication

3.1 MFA Requirements

Multi-Factor Authentication is mandatory for the following access (PCI DSS Requirement 8.4):

- ALL access to the cardholder data environment regardless of user role or network location
- ALL remote access to corporate networks and systems
- ALL administrative access to CDE systems and infrastructure
- ALL cloud management console access
- ALL access to security management systems (SIEM, PAM, vulnerability scanners)

3.2 Approved MFA Methods

Hardware security key (FIDO2/ WebAuthn)	Yes – Preferred	Highest assurance; phishing-resistant
Time-based OTP app (TOTP)	Yes	Approved apps: Microsoft Authenticator, Google Authenticator
Hardware OTP token	Yes	RSA SecurID or equivalent
Push notification (authenticator app)	Yes	With number matching; be aware of MFA fatigue attacks
SMS OTP	No – CDE	Permitted for low-risk non-CDE systems only
Email OTP	No – CDE	Permitted for low-risk non-CDE systems only
Voice call OTP	No	Not permitted for any company systems

3.3 MFA Fatigue Prevention

To prevent MFA push fatigue attacks (where attackers repeatedly send approval requests):

- MFA push notifications must use number matching or additional context (location, app name)

- Users who receive unexpected MFA requests must decline and immediately report to the security team
- Three or more declined MFA requests within a short period must trigger a security alert
- MFA rate limiting must be configured to block excessive authentication attempts

4. Password Management

4.1 Password Storage

Passwords must never be stored in recoverable form. The following requirements apply to all systems storing credentials:

- Passwords must be hashed using an approved adaptive hashing algorithm: bcrypt, scrypt, Argon2, or PBKDF2 with at least 10,000 iterations
- MD5, SHA-1, and unsalted SHA-2 are prohibited for password storage
- Each password hash must use a unique, cryptographically random salt of at least 32 bytes
- Password hashes must be stored separately from usernames and other identifying information where feasible
- Plaintext passwords must never be logged, transmitted over unencrypted channels, or stored in any form

4.2 Password Transmission

- Passwords must only be transmitted over encrypted channels (TLS 1.2 minimum)
- Systems must not allow password transmission over HTTP, Telnet, FTP, or other unencrypted protocols
- Password reset links must be transmitted over HTTPS and expire within 1 hour
- Temporary passwords must be changed at first use

4.3 Password Managers

Use of approved enterprise password managers is encouraged for all users and required for privileged accounts. Approved password managers provide:

- Encrypted password storage with a master password and MFA protection
- Password generation with complexity meeting or exceeding organizational requirements
- Auditing and reporting for security team oversight
- Integration with company SSO and PAM solutions

5. Account Management

5.1 Account Provisioning and Unique IDs

Authentication and access control effectiveness depends on individual accountability:

- Every user must have a unique, individually assigned user ID — sharing of accounts is strictly prohibited
- User IDs must identify the individual user; generic IDs are prohibited for interactive accounts
- User IDs must not be reused after an account is terminated or deactivated
- New accounts must go through the access provisioning process defined in the Access Control Policy

5.2 Default and Vendor Accounts

Default credentials represent one of the most common attack vectors in payment card breaches:

- All default accounts and passwords must be changed or disabled before any system goes into production or is connected to the network
- A full inventory of default accounts for each system type must be documented
- Scanning for default credentials must be included in vulnerability assessment procedures
- Vendor-supplied accounts must be deactivated when not in use

5.3 Inactive Accounts

- Accounts unused for more than 90 days shall be automatically disabled (30 days for CDE accounts)
- Disabled accounts shall be retained for 90 days before deletion to allow for audit purposes
- Automated alerts shall notify the account owner and their manager 14 days before automatic disablement

6. Session Management

6.1 Session Timeout

CDE interactive sessions	15 minutes	8 hours
CDE privileged/admin sessions	10 minutes	4 hours
Web applications processing CHD	15 minutes	8 hours
VPN/remote access sessions	30 minutes idle	12 hours
Non-CDE systems	30 minutes	24 hours

6.2 Concurrent Sessions

To prevent unauthorized use of stolen credentials:

- CDE system access shall be limited to one concurrent session per user ID
- Alerts shall be generated when concurrent logins are detected for the same user account
- Administrative accounts shall not permit concurrent sessions from different source IPs

7. User Responsibilities

7.1 User Obligations

All users are responsible for:

- Selecting passwords that comply with this Policy and keeping them confidential
- Never sharing passwords, credentials, or MFA devices/codes with anyone
- Reporting suspected compromised passwords to the Security team immediately
- Using only approved password managers; not storing passwords in browsers on CDE systems
- Changing passwords when requested by the Security team, even outside the regular rotation schedule

8. Revision History

1.0	Jan 15, 2024	Initial release	CISO Office
1.2	Jun 30, 2024	MFA methods table; MFA fatigue section; PCI DSS v4.0 Req 8 alignment	Security Team

1.5	Apr 14, 2026	Annual review; session management table; password storage algorithm updates	CISO Office
-----	--------------	---	-------------